Aqsa Khalid
Lecturer
School of Computing

CS3002 Information Security



Malware Study and Prevention - II

Virus



- "A program that can infect other programs by modifying them to include a, possibly evolved, version of itself"
  (Fred Cohen 1983)

- It executes secretly when host program is run
- Inserts copies of itself into host programs/data files
- Requires user interaction for initial trigger
- Often specific to operating system and hardware
  - taking advantage of their details and weaknesses

Four phases of Virus



- **Dormant**: It is idle, waiting for some event
- **Propagation**: Copy itself into other programs or key disk areas, or to other computers over the network, or spread via email
- **Triggering**: activated to perform some intended actions
- **Execution**: perform the function contained in the payload

Lifecycle of virus



- A virus gets created and released
- The virus infects several machines
- Samples are sent to anti-virus companies
- AV companies record a signature from the virus
  - Then include the new signature in their database
- Their scanner now can detect the virus

Classification of Viruses



Payloads — What it does after infection

- No Payload
- Non Destructive
- Destructive
- Droppers

Targets — What exactly it infects

- Compiled
  - File infector
  - Boot sector
- Interpreted
  - Macro
  - Script
- Multipartite

Obfuscation Techniques — How it evades detection

- No Obfuscation
- Encrypted
- Oligomorphic
- Polymorphic
- Metamorphic
- Stealth
- Armoured
- Tunneling
- Retrovirus

Dropper Payloads



- A virus that is designed to drop more malware on the computer
- Does not do malicious activities by itself, but download/decompress more malware and install it
- It acts as a container or carrier that encapsulates additional malware components.

Obfuscation Techniques



Techniques that are being used to avoid detection and analysis!

1. **No Obfuscation**

- easier to build
- detection and analysis of such a virus is trivial

Obfuscation Techniques



obfuscating the virus code

2. Encryption

- use of cryptography to hide the functionality
- includes a decryptor routine (function) along with the encrypted body that decrypts the virus on-the-fly
- a new encryption key is chosen when infecting a new file
- the decryption key can:
  - exist in the virus body along with the decryption algorithm
  - be recovered with a simple brute force by the virus itself

Obfuscation Techniques



obfuscating the virus code

3. Oligomorphism

- also called 'Semi-polymorphic'
- use multiple decryption routines to avoid giving a signature for the antivirus software
- There are some pre-defined decryption routines, one of them chosen randomly on infection
  - so can still be detected via signatures

4. Polymorphism

- change the look of the virus code every time it infects a new file by dynamically changing the decryption routine
- can create very large number of decryption routines using a 'mutation engine', which has all the logic in creating a new decryption routine

Obfuscation Techniques



obfuscating the virus code

5. Metamorphism

- change the virus body for each infection
  - without using encryption
- mutation is done by using equivalent and unneeded functions (or code) or by changing the sequence of statements in the code slightly (as long as the logic remains same)
- every specimen looks different and generation of a signature is much harder
- more advanced metamorphs also change their runtime behavior, not just the code

Obfuscation Techniques



obfuscating the virus' actions

6. Stealth

- tries to remain undiscovered by hiding the infection events from everyone, instead of trying to obfuscate its code
- achieves this by restoring certain original properties
  - e.g. timestamp, file size

7. Armoring

- uses various anti-debugging, anti-heuristics and anti-VM (virtual machine detection) techniques
- may use file packers, copying itself to multiple sections in the host file

Obfuscation Techniques



obfuscating the virus' actions

8. Tunneling

- hooks into operating system interrupts
- virus executes first and after that the control is passed to the original destination

Obfuscation Techniques



obfuscating the virus' actions

9. Retro Virus

- tries to bypass or hinder the operation of an antivirus, personal firewall, or other security programs.
- also called 'Anti-antivirus viruses'
- they generally have a database of identification mechanisms for different security controls like process names, registry keys. Once identified, the security controls can be terminated or corrupted
- block users from updating their antivirus software or opening of system utilities or antivirus vendor websites

Comparison of Malware Types



Malware	Host Required	Replication Mechanism
Virus	Yes	Self
Worm	No	Self
Logic Bomb	No	Manual
Backdoor	No	Manual
Trojan	Yes	Manual
Spyware	No	Manual
Rootkit	No	Manual
Bots	No	Manual

Host required: Malware is first loaded on to a host file (executable, script, document etc.), it will run only when the user executes or opens the host file.

What is infected by malware?



- Executables
- Interpreted scripts
- Kernel
- System services
- MBR (Master Boot Record)
- Hypervisor

How exe files are altered



- When a compiled malware infects an executable file, it may:
  - replace all of existing code

  OR

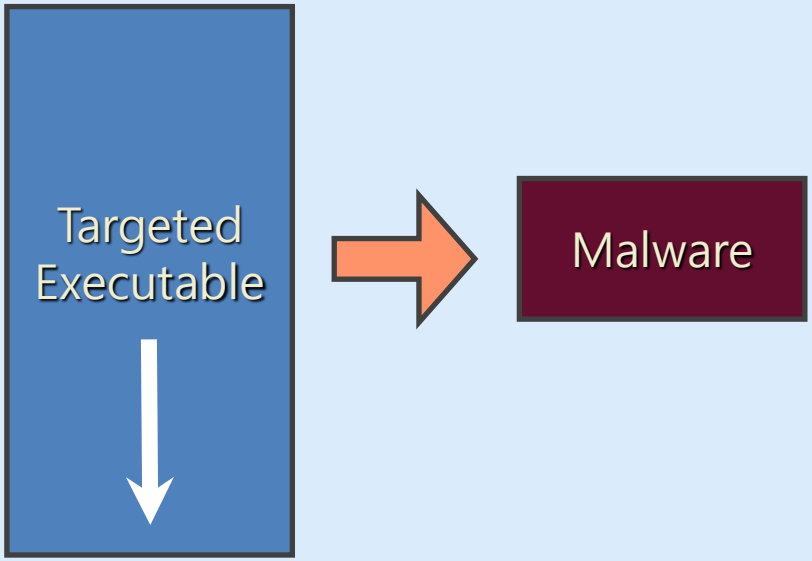
  - add the malicious code while keeping original code (and functionality) intact

Some common methods employed by malware are shown next…

Overwriting malware

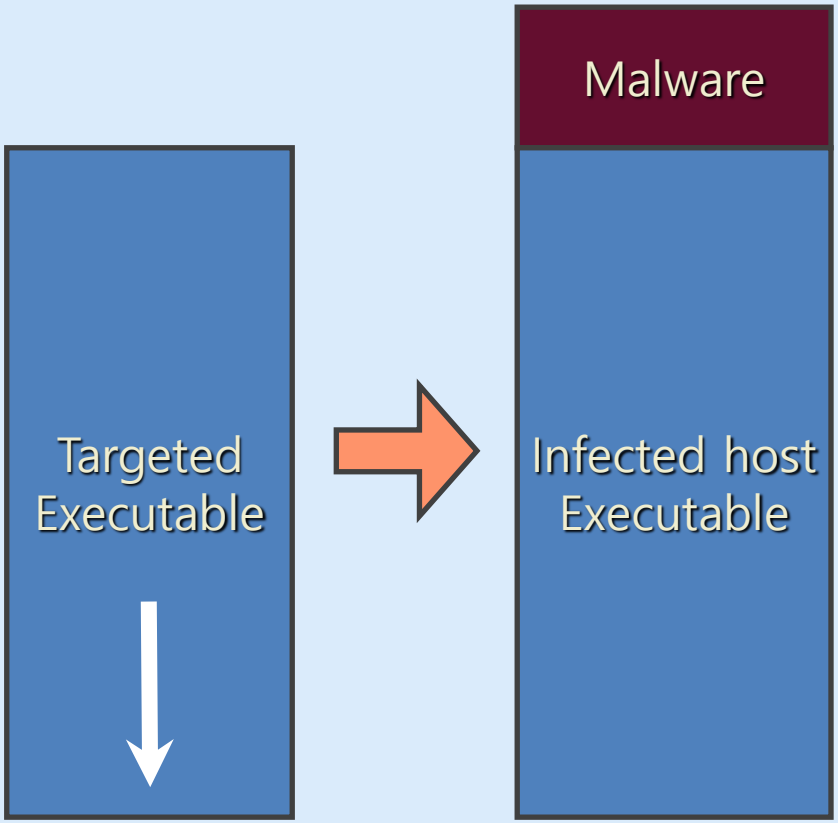


- After infection, it will effectively destroy the original program code by overwriting it on disk or in system's memory.
  - TRj.reboot virus: It can restart the user's computer, and was active in targeting Windows NT and Windows 2000 systems in the 2000s.
  - Trivial.88.D virus: A 'direct action virus' that infects executable files.



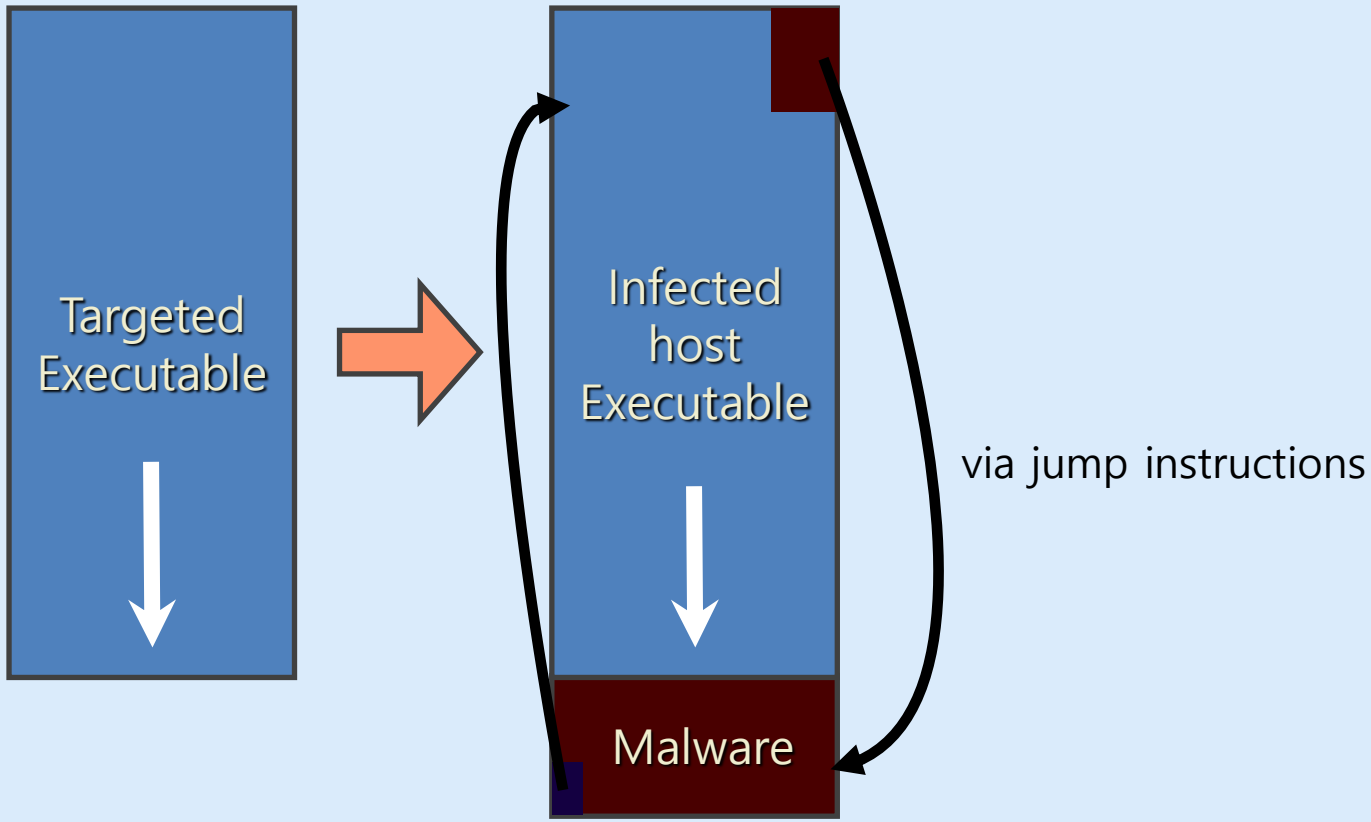
Prepending malware





Appending malware

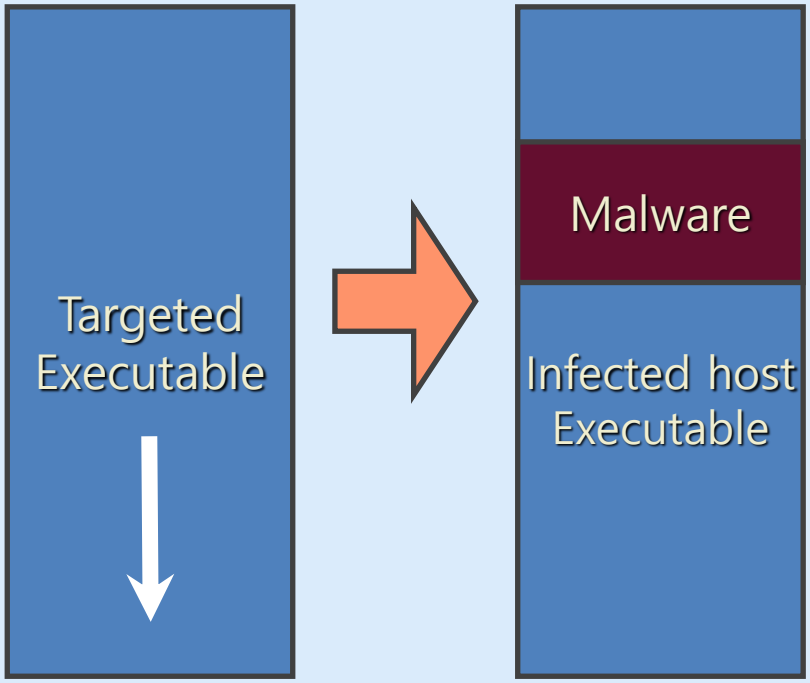




Cavity malware



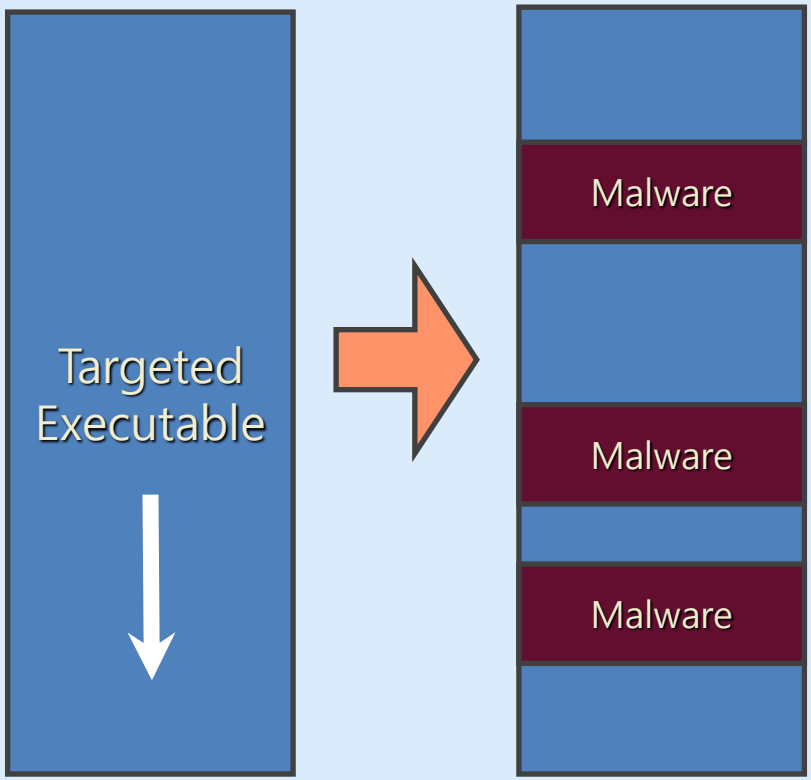
- Some viruses can infect files without increasing their sizes or damaging the files by overwriting unused areas of executable files. These are called cavity viruses.
- For example, the CIH virus, or Chernobyl Virus which infects Portable Executable files.



Multi-cavity malware



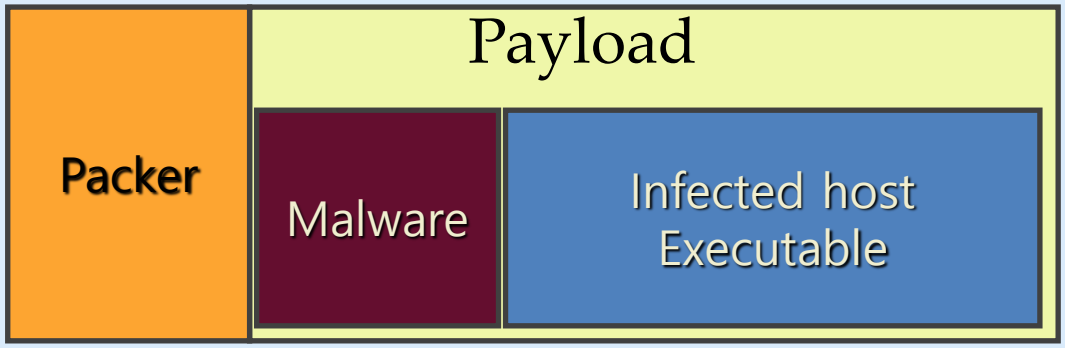
- In case the malware does not find one cavity big enough to hold the complete code



Packer



- A packer compresses and optionally encrypts data. The original file is passed in the packer routine and stored in a packed section in the new .exe.



Malware Analysis



- Malware analysis is the study or process of determining the functionality, origin and potential impact of a given malware. (Wikipedia)

- Three typical use cases of analysis
  - Computer security incident management
  - Malware research
  - Indictor of compromise extraction
- Analysis types
  - Static
  - Dynamic

Why analyze malware



- To assess damage
- To discover indicators of compromise
- To determine sophistication level of an intruder
- To identify a vulnerability
- To catch the “bad guy”
- To answer business related questions
  - How long has it been here, spreads on its own? etc.
- To answer technical questions
  - Date of installation, compilation, persistence mechanism, network or host based indicators

Static Analysis



- Analysis in which code is not executed
- "Dead" code is read and understood
  - Also referred to as: code analysis
- Requires inspecting file metadata and dependencies, performing string searches, peeking into the file using a hex editor.
- Code can be studied after disassembling the malware
  - Disassemblers (e.g. IDA Pro) convert machine code to higher-level assembly code.
- How about packer malwares?
  - Tools like PEiD, Mandiant Capa can tell you about "packed" code
  - Unpacking is needed before further static analysis

Dynamic Analysis



- Conducted by observing and manipulating malware as it runs
- Needs a safe (**sandboxed**) environment to analyze (run) the code
- Requires monitoring the system
  - Registry files activity
  - File and process/system level activity
  - Network level activity
- Some tools
  - Wireshark
  - SysInternals process monitor (windows)
  - netstat (Windows/Linux) or ResMon (Windows)
- Requires analysis while the code is being run using debugging tools like WinDbg/GDB
- Malware files are fingerprinted before analysis — in case malware triggers a self-corruption during analysis.

Sandboxing



- The process of isolating a program on the hard drive in order to minimize or eliminate the exposure to other apps and critical system.
- Usually programs and applications interact with multiple parts of operating system and use shared resources like storage, memory and CPU sometimes causing conflicts.
- A malware if present can utilize such vulnerabilities to cause a disaster.
- Sandboxing helps to reduce the impact that an individual program will have on the system.

Static vs Dynamic Analysis



- Static: Dissecting code via different resources without executing
- Dynamic: Behavioral analysis is performed by executing the malware.
- Static is much slower (and exhaustive at times) as compared to dynamic.
- Static is far safer than dynamic.
- Static doesn't (necessarily) need a sandboxed environment while dynamic does.

References



- Stallings SPP chap 6